| | |
|---|---|
| **TD WiFi**<br>Architecture et Sécurité des Réseaux sans Fil<br>CRC, WEP et WPA/WPA2 | INSA-Lyon<br>Département Télécom<br>Walid Bechkit |

# 1 Le contrôle de redondance cyclique : calcul et failles

Comme vu lors du cours et des TPs, plusieurs attaques contre le protocole WEP se basent sur la linéarité du CRC. L'objectif de cet exercice est de mieux comprendre et de savoir calculer le CRC.

Afin de simplifier les calculs, on suppose qu'on utilise un CRC-4 ayant le polynôme générateur $x^4 + x^2 + x$.

1. On souhaite transmettre le message suivant :10100111 (A7 en hexa), quel sera le CRC à ajouter ?

2. On a reçu les messages suivants : 10110011 1010 , 10110001 1010, sont-ils corrects ?

3. Dans le protocole WEP, le CRC est calculé sur chaque message et ajouté à la fin avant de chiffrer ce dernier. Le message chiffré E(M) correspondant à chaque message, en clair, M s'écrira donc :

   $E(M) = (M||CRC(M)) \oplus KS$
   où KS est la suite chiffrante générée par RC4 à partir de IV et de la clé secrète K.

   Montrez qu'un attaquant peut modifier des messages des stations sans que cela soit détecté par le point d'accès et vice versa.

   Indice : n'oubliez pas que le CRC est linéaire par rapport au $\oplus$, autrement dit :
   $CRC(X \oplus Y) = CRC(X) \oplus CRC(Y)$

4. Nous considérons le message de la question 1 avec son CRC et nous supposons que la suite chiffrante est égale à :000011111111. Trouvez le message WEP chiffré.

5. On suppose que l'attaquant écoute ce message chiffré. Comment peut-il changer les deux dernier bit du message sans que cela soit détecté par le point d'accès.

6. On suppose maintenant qu'un attaquant a le contrôle sur un hôte sur internet ayant l'adresse IP (A.A.A.A). On suppose que le point d'accès est relié à internet et que les paquets sont envoyés en clair vers internet (liaison souvent filaire). Si l'attaquant capture un paquet IP (chiffré) pour lequel il connaît l'adresse IP de destination (B.B.B.B), peut-il déchiffrer ce paquet ? si oui, expliquez comment.

   Indice : vous pouvez vous baser sur les questions précédentes afin de proposer une simple attaque efficace.

7. Supposons que l'attaquant connaisse les n premiers octets de la suite chiffrante WEP. Il peut dans ce cas chiffrer des paquets de données de taille n-4.

| | | | | | | | | |
|---|---|---|---|---|---|---|---|---|
| D0 | D1 | D2 | D3 | D4 | I0 | I1 | I2 | I3 |
| $\oplus$ | $\oplus$ | $\oplus$ | $\oplus$ | $\oplus$ | $\oplus$ | $\oplus$ | $\oplus$ | $\oplus$ |
| KS0 | KS1 | KS2 | KS3 | KS4 | KS5 | KS6 | KS7 | KS8 |
| = | = | = | = | = | = | = | = | = |
| EM0 | EM1 | EM2 | EM3 | EM4 | EM5 | EM6 | EM7 | EM8 |

   En se basant sur le CRC, et sachant que le point d'accès va rejeter tout paquet présentant une erreur de CRC et accepter les paquets dont le CRC est correct, proposez une attaque permettant de déduire le KS9.

8. Quelle est la complexité de cette attaque : Quel est le nombre d'itérations max ? min ? moyen ? pour trouver un octet supplémentaire.

## 2 Authentification challenge/response et le chiffrement symétrique par flot

L'authentification WEP se base sur le modèle challenge response comme suit :

STA –> AP : authenticate request
AP –> STA : 128 byte authenticate challenge (r)
STA –> AP : authenticate response IV,E(r) = r $\oplus$ RC4(K||IV)
AP –> STA : authenticate success or failure

1. En écoutant un seul échange d'authentification, expliquez comment un attaquant peut lui même s'authentifier auprès d'un point d'accès sans pour autant connaître la clé secrete K.

## 3 Collision et chiffrement symétrique par flot

Une des failles WEP est due au chiffrement symétrique par flot et à la faible taille du vecteur IV qui fait 24 bits.

1. Pourquoi le vecteur d'initialisation est-il modifié à l'envoi de chaque paquet ?
2. Supposons que le vecteur d'initialisation IV soit incrémenté à chaque paquet, que les paquets fassent en moyenne 1000 octets et que le réseau fonctionne avec un débit de 54 Mbps. En combien de temps une collision pourrait se produire ?
3. Supposons que l'attaquant a pu écouter un message chiffré pour lequel il a pu deviner le message en clair (requête ARP, requête DHCP, etc.), quel serait le risque de confidentialité dû aux collisions étudiées dans la question précédente ?

## 4 WEP et WPA

1. Est ce que le filtrage d'adresses MAC seul peut empêcher un attaquant à se connecter au point d'accès ?

2. Expliquer pourquoi la faiblesse du protocole WEP ne pas pas être résolue en augmentant simplement la taille de la clé.

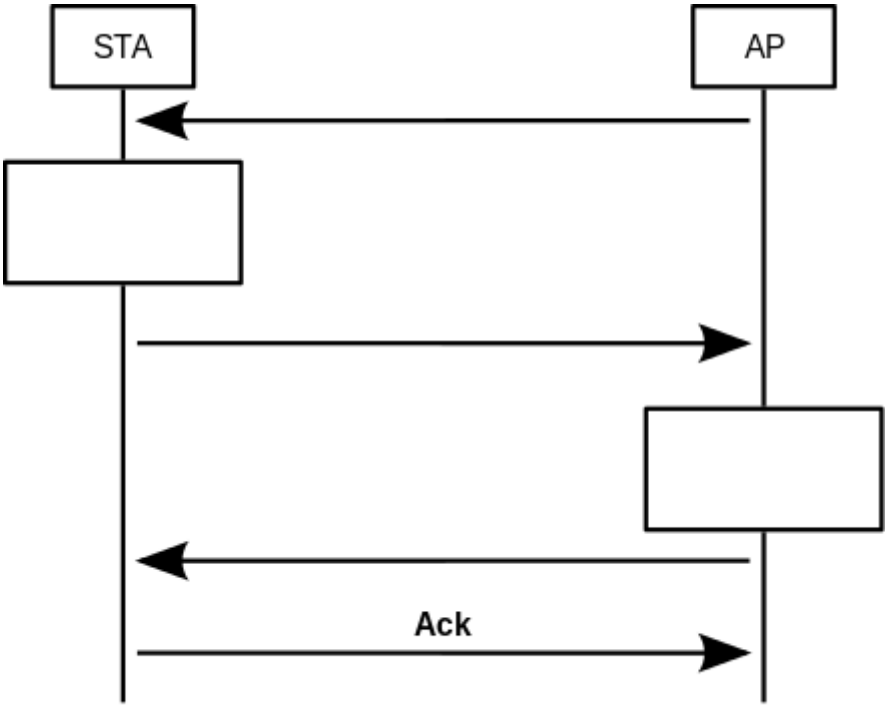
3. Comparez le chiffrement symétrique et le chiffrement asymétrique en donnant les avantages et les inconvénients de chacun.

4. Expliquez les différences entre le chiffrement symétrique par flot (stream Cipher) et symétrique par bloc (Block Cipher). Donnez un exemple de chacun. Quelle chiffrement recommandez-vous parmi les deux proposées par 802.11i.

5. Afin d'assurer la confidentialité des échanges en WPA (TKIP), un chiffrement par flot est toujours utilisé. Quels sont les précautions prises pour éviter les attaques précédentes ? Pourquoi ce mode a-t-il été maintenu en WPA ?

## 5 WPA2 : 4-way handshake

1. Sur la figure suivante des échanges WPA, précisez les informations les plus importantes échangées dans chacun des trois premiers messages. A quel moment et comment le STA authentifie-t-il le AP ? A quel moment et comment le PA authentifie-t-il le STA ?

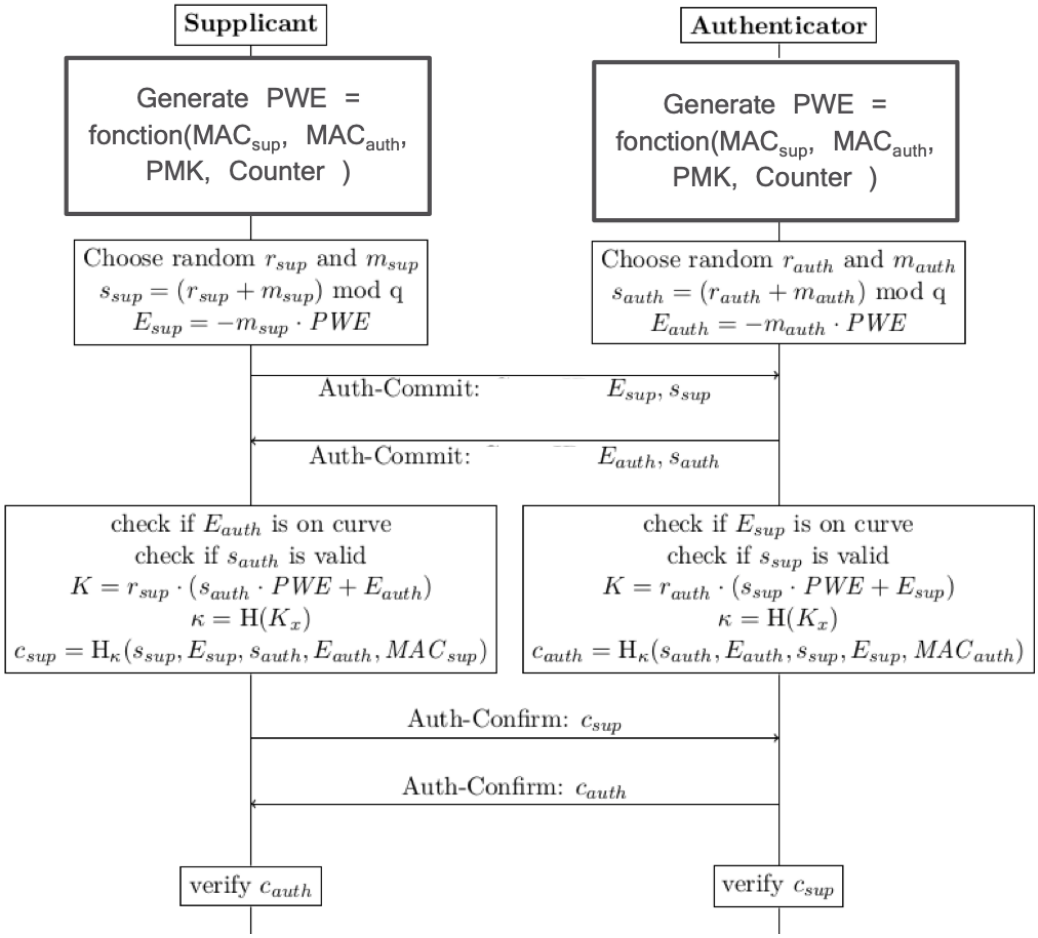


## 6 Attaque par dictionnaire contre WPA et WPA2

1. En se basant sur l'exercice précédent, donnez un pseudo algorithme permettant d'expliquer le déroulé d'une attaque par dictionnaire (offline) contre WPA/WPA2.
2. Pourquoi l'attaque par dictionnaire est-elle parmi les plus utilisées pour retrouver les clés WPA et WPA2 ?
3. Sachant qu'un simple ordinateur peut tester jusqu'à 1 000 000 clés par seconde, quel est le temps nécessaire pour casser une clé comprenant 6 caractères alphabétiques ? numériques ? alphanumériques ? quelconques ?

## 7 WPA3

1. En se basant que les échanges WPA3 ci dessous, expliquez pourquoi est-il difficile (impossible en pratique) de mener une attaque par dictionnaire contre WPA3.




## 8 Références


— Jean Leneutre, TD Vulnérabilités UE INF721, Télécoms ParisTech, disponible sur : https ://hoper.dnsalias.net/tdc/public/3INF721-TD1-vulnerabilites-wep-sujet.pdf dernier accès 10-02-2017

— Alan Holt and Chi-Yu Huang 802.11 Wireless Networks Security and Analysis, Springer, 2010.

— Aircrack-ng : https ://www.aircrack-ng.org/